

1. 업무 개요

△△△△본부(◇◇◇◇◇처 ◇◇◇◇부, 이하 “◇◇◇◇부”라 한다)는 「정보보안 업무지침」 제52조에 따른 정보시스템의 관리부서로서 시스템 접근 권한 부여 등 공용(公用) 정보시스템¹⁾의 계정 관리를 하고 있다.

2. 판단 기준

「개인정보보호법」 제29조(안전조치의무)에 “개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다”고 규정하고 있다.

공단 「정보보안 업무지침」 제76조(계정 관리)에 따르면 “공용(公用) 정보시스템 관리자²⁾는 개별사용자의 보직변경, 퇴직, 계약종료 등 변동사항이 발생할 경우 신속히 사용자 계정을 삭제하거나 부여된 접근권한을 회수하고, 사용자 계정 부여 및 관리의 적절성을 연 2회 이상 점검하여 그 결과를 정보보안담당관³⁾에게 통보 하여야 한다”고 명시되어 있다.

또한, 「인사규정」 제4조에 직위해제란 “일정한 기간 직위⁴⁾를 해제함을 말한다”고

1) 공용(公用)정보시스템 : 업무포털, 경영정보시스템(MIS), 전자결재시스템, 웹메일

2) 공용(公用)정보시스템 관리자 : ◇◇◇◇부 시스템 업무 담당자

3) 정보보안담당관 : △△△△본부 ◇◇◇◇◇처장

4) 1명의 직원에게 부여할 수 있는 직무와 책임

되어있으며, 제74조에 강등은 “1계급 아래로 직급을 내리고 직원의 신분은 보유하나 3개월간 직무에 종사하지 못한다”, 정직은 “정직은 1개월 이상 3개월 이하의 기간으로 하고 정직처분을 받은 자는 그 기간 중 직원의 신분은 보유하나 직무에 종사하지 못한다”고 명시되어 있다.

따라서, ◆◆◆◆부에서는 직위해제자 및 징계자를 포함한 개별사용자의 보직 변경, 퇴직, 계약종료 등 변동사항이 발생할 경우 신속히 사용자 계정을 삭제하거나 부여된 접근권한을 회수하여야 한다. 또한, 사용자 계정 부여 및 관리의 적절성을 연 2회 이상 점검하여 그 결과를 정보보안담당관에게 보고하여야 한다.

3. 감사결과 확인된 문제점

그러나, “내부통제 및 방만경영 특정감사” 요구자료로 “공용(公用) 정보시스템 계정 접근권한 현황”을 ◆◆◆◆부로부터 받아 검토한 결과 아래 [표1]과 같이 징계(㉠㉠) 중인 직원 *명이 공용 정보시스템(업무포털, MIS, 전자결제, 웹메일)에 접근 할 수 있는 것으로 확인하였다.

[표1] ㉠㉠5)의 시스템 접근권한 현황

성함 및 직책	소속	㉠㉠일자	접근권한 시스템
◆◆◆ ◆◆◆	㉠㉠㉠㉠㉠㉠본부 ◆◆◆◆◆◆처 ◆◆◆◆부	0000-00-00 (㉠㉠㉠)	경영정보시스템(MIS), 업무포털, 웹메일, 전자결제시스템

또한, 감사실에서는 감사실 소속의 휴직직원 통해 시스템 권한 부여 현황을

5) ㉠㉠처분을 받은 자는 그 기간 중 직원의 신분은 보유하나 직무에 종사하지 못하며 보수는 전액 감액한다(인사규정)

점검한 결과, 감사실 소속 휴직직원이 MIS에서 공단 전직원의 복무기록을 확인할 수 있는 등 감사권한이 적절하게 회수되지 않았음을 확인하였다.

공용(公用) 정보시스템 관리자는 사용자의 변동사항이 발생한 경우 사용자 계정을 삭제했는지, 부여된 접근권한을 회수했는지 사용자 계정 부여 및 관리의 적절성을 연 2회 이상 점검하여 그 결과를 정보보안담당관인 ◇◇◇◇◇처장에게 보고하여야 하나 “내부통제 및 방만경영 특정감사” 자료요구에 따른 제출자료를 검토한 결과 점검을 이행하지 않은 것으로 확인하였다.

또한, ◇◇부는 임직원의 변동사항이 발생했을 경우, 사용자 계정 삭제 또는 부여된 접근권한이 회수 될 수 있도록 그 변동사항과 시스템 접근권한의 범위를 정하여 ◇◇◇◇부에 알려줄 필요가 있으나 관련 절차가 마련되어 있지 않은 것으로 확인하였다.

인사, 계약, 회계, 예산 등 중요정보를 담당하는 부서의 직위해제 직원, 징계 중인 직원이 공용(公用) 정보시스템 접근을 통해 개인정보, 계약정보 등의 민감한 정보를 확인하고 활용할 위험이 있을 수 있음에 따라, 인사발령에 따른 시스템 접근권한이 적절하게 회수될 수 있도록 절차를 마련하고 주기적인 사용자 계정 부여 및 관리의 적절성 점검을 통해 직위해제, 징계 중인 직원의 경우 신속히 부여된 접근권한을 회수할 필요가 있다.

4. 관련자(부서) 의견

◇◇◇◇부에서는 향후 인사발령에 따른 시스템 접근권한 회수 절차가 마련되

고 ㉠㉠부 요청 시 시스템 접근권한을 회수할 예정이며 공용(公用) 정보시스템 관리자뿐 아니라 인사, 계약, 회계, 예산 등 주요 정보를 담당하는 부서가 관련 사용자 계정별 권한 부여 및 관리의 적절성을 점검하도록 함께 보완하여 공용(公用) 정보시스템 접근권한 관리가 강화할 수 있도록 개선하여 운영 예정이라는 의견을 제시하였다.

5. 조치할 사항

① △△△△이사(㉠㉠㉠㉠㉠장)는 사용자 계정 부여 및 관리의 적절성을 연 2회 이상 점검을 하지 않은 △△△△본부 ㉠㉠㉠㉠처 ㉠㉠㉠㉠부에 “주의” 조치하시기 바랍니다. 【주의】

② △△△△이사(㉠㉠㉠㉠㉠장)는 사용자의 직위해제, 징계 등 변동사항이 발생할 경우 신속히 시스템 접근 권한이 회수될 수 있도록 ㉠㉠㉠㉠부에 요청하는 등 방안을 마련하시기 바랍니다. 【권고】

③ △△△△이사(㉠㉠㉠㉠㉠처장)는 변동사항이 발생한 직원의 시스템 접근 권한을 신속히 회수하시기 바랍니다. 【시정】